

⚡ AI Cyber Threat Landscape

TLP:GREEN — INTERNAL USE

Weekly Executive Intelligence Brief

Week of 12–15 May 2026

Based on open source intelligence (OSINT) · Prepared by an AI intelligence analyst

Issued: 15 May 2026, 10:07 EDT

Prepared by: AI Intel Analyst

⚠ OVERALL RISK
ELEVATED

AI-powered offensive tooling has crossed a capability threshold this week. **Agentic attack frameworks operating without human-in-the-loop** are confirmed in at least two nation-state campaigns. Concurrently, the AI infrastructure layer itself is under attack — an actively exploited **Microsoft SSO Plugin zero-day** (CVSS 9.1) is compromising Jira and Confluence environments at scale, and a **Palo Alto PAN-OS zero-day** (CVE-2026-0300) linked to a China-nexus actor has been weaponized since April. The merger of AI-as-weapon and attacks-on-AI defines the current threat moment.

THIS WEEK AT A GLANCE

6

NEW CRITICAL / HIGH
CVES

↑ 3 vs last week

4

UNPATCHED ZERO-DAYS

— ongoing

2

ACTIVE CISA KEV
DEADLINES

1 PASSED today

73%

PROD AI APPS W/
PROMPT INJECTION RISK

⚠ Analyst est. — [Zylos AI](#)

RISK POSTURE BY DOMAIN

AI-POWERED ATTACKS

CRITICAL — 88/100

AI INFRASTRUCTURE
SECURITY

HIGH — 79/100

DEEPFAKE / SOCIAL
ENGINEERING

CRITICAL — 82/100

SUPPLY CHAIN / LLM
POISONING

HIGH — 70/100

AI AS A WEAPON — ACTIVE THREAT VECTORS



Agentic AI Attack Chains

Autonomy Level: High — confirmed in-the-wild

Nation-state and criminal actors are deploying **autonomous AI agents** that execute full intrusion lifecycles — recon, exploitation, lateral movement, and exfiltration — without human operators in the loop. MuddyWater (Iran-MOIS) used an AI-assisted campaign in April 2026 masquerading as Chaos ransomware. Chinese-nexus TGR-STA-1030 is actively probing 155 countries using agentic tooling. **Time-to-exploit has compressed to hours.**

Nation-State

Active Exploitation

Autonomous



Deepfake & Voice Cloning BEC

Deepfake-as-a-Service now ~\$200/month

Deepfake audio/video involved in **>30% of high-impact corporate impersonation attacks** in 2025 (Cyble). Modern deepfake video **bypasses detection tools with >90% accuracy**. [SheByte PhaaS](#) platform delivers AI-generated templates at scale. Scattered Spider + Russian ransomware partnerships now combine Western social engineering with Eastern technical capability. **A \$25M Hong Kong fraud remains the benchmark.**

BEC / Fraud

\$25M+ incidents

PhaaS



AI-Generated Phishing at Scale

Spear-phishing at spray-and-pray volume

LLMs now produce **hyper-personalized, multilingual phishing lures at mass scale**. ClickFix browser-based attacks (AI-generated fake CAPTCHAs tricking users to execute code) are escalating rapidly. AI-adaptive lures adjust tone and content mid-interaction. **Traditional awareness training is no longer sufficient** — the content is indistinguishable from legitimate communications without process controls.

Phishing

ClickFix

Browser-Based



Ransomware 5.0 — Autonomous Operations

Fully autonomous ransomware PoCs confirmed

The next evolution: AI embedded in **every stage of the ransomware chain**. AI generates access, maps networks in minutes, chains exploits on the fly, refactors malware in real-time to evade signatures, and runs extortion negotiations autonomously. PoC frameworks are public. **TeamPCP released Shai-Hulud worm source code this week**, demonstrating AI-guided self-propagation. A semi-autonomous campaign is no longer a prediction — it is a timeline question.

Ransomware

Public PoC

Autonomous

ATTACKS ON AI SYSTEMS — INFRASTRUCTURE UNDER SIEGE



Prompt Injection (OWASP LLM01)

73% of production deployments remain exposed

Prompt injection is the #1 LLM vulnerability per [Zylos AI](#). **Indirect injection** — via poisoned documents, web content, and RAG pipelines — now accounts for **>55% of observed incidents**, with 20–30% higher success rates than direct attacks. **73% of production AI deployments remain exposed**. The EchoLeak attack against M365 Copilot demonstrated zero-click corporate data exfiltration.

OWASP LLM01

RAG Poisoning

Zero-Click



AI Supply Chain & Model Poisoning

250 malicious docs = backdoor in any LLM

[Research](#) (Anthropic / UK AI Security Institute / Alan Turing Institute, Oct 2025) confirms **as few as 250 malicious documents** can backdoor models from 600M–13B parameters. OpenAI hit by TanStack supply chain attack this week. ShadowLogic backdoors survive format conversion and fine-tuning. Hugging Face model downloads remain unverified in most enterprise deployments. **MCP server misconfigurations** enable tool poisoning, credential exfiltration, and code execution at the agent layer.

Supply Chain

Backdoor

MCP Risk



Jailbreaking & Guardrail Bypass

Policy Puppetry bypassed all major frontier models

Policy Puppetry — a universal jailbreak technique — successfully bypassed safety guardrails across all major frontier models in 2026. Per [Zylos AI 2025 systematic research](#): roleplay-based attacks achieve **89.6% success rate**; logic trap attacks 81.4%. iMIST (multi-step tool-disguised jailbreak) uses RL to iteratively erode safety barriers across multi-turn conversations. Guardrails are necessary but **cannot be the only control** — they are routinely bypassed.

Guardrail Bypass

89.6% ASR

Multi-Turn



CVE-2026-7482 — Bleeding Llama

Ollama heap OOB read — CVSS 9.1 — PATCHED

Bleeding Llama (CVE-2026-7482) — a heap out-of-bounds read in Ollama AI inference server — allows unauthenticated attackers to exfiltrate **API keys, environment variables, and chat session data** from AI inference endpoints. Affects all Ollama versions <0.17.1. Most enterprise AI lab deployments ship Ollama on default (unauthenticated) configuration. Patched in v0.17.1. **Prioritise patching any internal Ollama instance immediately**.

Patched

CVSS 9.1

API Key Theft

CRITICAL VULNERABILITIES — WEEK OF 12–15 MAY 2026

CVE / ID	PRODUCT	TYPE	CVSS	STATUS	AI RELEVANCE
CVE-2026-42897	Microsoft Exchange OWA	XSS → RCE (Zero-Day)	—	❑ UNPATCHED	AI BEC pivot via compromised email infrastructure
CVE-2026-41103	MS SSO Plugin — Jira / Confluence	Auth Bypass / Identity Forgery	9.1 CRIT	⚡ ACTIVELY EXPLOITED	AI knowledge base + issue tracker takeover
CVE-2026-20182	Cisco Catalyst SD-WAN	Auth Bypass — Full Admin	10.0 CRIT	⚡ CISA KEV — May 17 FCEB	Network segmentation bypass for AI workload isolation
CVE-2026-41651	PackageKit (Linux)	LPE / TOCTOU — Pack2TheRoot	8.8 HIGH	⚡ ACTIVELY EXPLOITED	LPE on AI inference / training servers
CVE-2026-40402	Windows Hyper-V	EoP / Guest-to-Host Escape	9.3 CRIT	✅ Patched May PT	Cloud AI workload isolation breach
CVE-2026-0300	Palo Alto PAN-OS	Unauthenticated RCE (Buffer Overflow)	CRITICAL	✅ Patched May 13	Perimeter breach for AI DMZ networks; China-nexus actor
CVE-2026-7482	Ollama AI Inference Server	Heap OOB / Data Exfiltration	9.1 HIGH	✅ Patched v0.17.1	Direct AI infrastructure attack — API key theft

✂ THE AI ARMS RACE

❑ OFFENSIVE AI CAPABILITIES

› Autonomous recon & exploitation chains

› Hyper-personalized phishing at spray-and-pray scale

› Real-time deepfake voice/video (undetectable by 2026)

› Adaptive malware that refactors against AV signatures

› AI-optimized psychological operations

› Jailbreak automation (89.6% success rates)

› Ransomware 5.0 — fully autonomous negotiation bots

› Model backdooring via <250 poisoned documents

VS

❑ DEFENSIVE AI CAPABILITIES

› Behavioral UEBA detecting anomalous AI agent actions

› AI-powered SOC alert triage and prioritization

› NVIDIA NeMo Guardrails (1.4× detection improvement)

› Automated AI red teaming (24/7 continuous)

› Runtime inference monitoring for prompt injection

› AI-driven deepfake detection (accuracy degrading)

› Provenance-tagged RAG document pipelines

› Model signing + supply chain verification

⚠ Analyst Assessment: Offensive AI is currently outpacing defensive AI in adaptability and scale. The Q3 2026 projection is analyst judgement based on current capability trends — not a sourced forecast.

❑ KEY INCIDENTS & INTELLIGENCE — THIS WEEK

❑❑ MuddyWater — AI-Assisted Intrusion Masquerading as Ransomware

Nation-State

May 2026

Iran-linked MuddyWater (MOIS) conducted an AI-assisted intrusion using Chaos ransomware as a false flag. Operations included AI-assisted recon, credential harvesting, and data theft with no actual ransomware deployed. **Assessment: ransomware artifacts were**

planted specifically to complicate attribution and mislead IR teams. The use of fake Chaos samples suggests AI-aided obfuscation tooling.

❏ OpenAI Hit by TanStack Supply Chain Attack

Supply Chain May 14, 2026

OpenAI's infrastructure was impacted by a supply chain compromise via the TanStack JavaScript library. This is emblematic of the broader trend: **AI vendors themselves are becoming high-value supply chain targets**. Any organization consuming OpenAI APIs or embedding OpenAI models should review their dependency trees and API key rotation posture.

❏ TeamPCP Releases Shai-Hulud Worm Source Code

Worm / AI-Guided This Week

Criminal group TeamPCP publicly released source code for the Shai-Hulud AI-guided network worm. **Public availability will accelerate adoption by lower-skill actors**. The worm uses LLM-guided decision trees for propagation path selection. Expect derivative variants in the wild within 30 days.

✓ EXECUTIVE RECOMMENDED ACTIONS

ACTION 01

Patch Cisco SD-WAN & Exchange Zero-Day

CVE-2026-20182 (CVSS 10.0) FCEB deadline is May 17 — two days. Apply Cisco patches immediately. CVE-2026-42897 (Exchange OWA) has no patch yet; apply OWA mitigations and restrict external OWA access now.

48-HOUR DEADLINE

ACTION 02

Audit All Jira / Confluence SSO Deployments

CVE-2026-41103 (CVSS 9.1) is actively exploited and allows complete identity forgery in Jira/Confluence. Patch to v1.3.3 and rotate all service account credentials immediately. Review audit logs for unauthorized access.

IMMEDIATE

ACTION 03

Inventory & Patch All Ollama / AI Inference Servers

Bleeding Llama (CVE-2026-7482) targets internal AI deployments directly. Audit all Ollama instances, enforce authentication, upgrade to v0.17.1+, and rotate any API keys that may have been exposed.

IMMEDIATE

ACTION 04

Implement Wire-Transfer Verification Process

Deepfake BEC is undetectable by technology alone. Mandate out-of-band voice verification (pre-shared codeword or callback to known number) for any wire transfer, vendor change, or executive-requested action exceeding a defined threshold.

THIS WEEK

ACTION 05

Assess AI Supply Chain Exposure

Review all third-party AI model sources (Hugging Face, etc.), MCP server configurations, and AI plugin permissions. Implement model signing verification and least-privilege agent credentials. TanStack supply chain event affects OpenAI consumers.

THIS MONTH

ACTION 06

Deploy Runtime AI Security Monitoring

Move beyond guardrails-only. Implement runtime inference monitoring to detect prompt injection in production AI systems. Guardrails are bypassed in 73% of tested deployments — runtime visibility is the required next layer.

Q2 PRIORITY

❏ SOURCES & CITATION NOTES

#	STAT / CLAIM	SOURCE	LINK
1	73% of prod AI deployments exposed to prompt injection	Zylos AI — LLM Security & Safety 2026	zylos.ai
2	89.6% / 81.4% / 76.2% jailbreak attack success rates	Zylos AI — 2025 systematic research	zylos.ai

#	STAT / CLAIM	SOURCE	LINK
3	250 malicious documents can backdoor any LLM (600M–13B)	Anthropic / UK AI Security Institute / Alan Turing Institute (Oct 2025)	anthropic.com
4	>30% of corporate impersonation attacks used deepfakes	Cyble Executive Threat Monitoring Report	cyble.com
5	>90% deepfake bypass rate against detection tools	Cyble Deepfake-as-a-Service 2025 Report	cyble.com
6	\$25M Hong Kong deepfake fraud	Cyble 2026 Outlook / widely reported	cyble.com
7	SheByte PhaaS ~\$200/month	SecurityWeek — Cyber Insights 2026: Social Engineering	securityweek.com
8	CVE data, patch status, CISA KEV entries	CISA KEV / Microsoft MSRC / BleepingComputer May 2026 PT	cisa.gov · bleepingcomputer.com

⚠ Analyst Assessments — Not Externally Sourced

- **Risk domain scores** (88, 79, 82, 70 /100) — analyst synthesis of aggregated OSINT; not derived from a single scored framework.
- **Q3 2026 capability gap projection** — analyst trend judgement; not a sourced forecast.
- **Week-on-week prompt injection delta** — the 73% figure is sourced; the comparative baseline is an interpolated estimate.